

TRYHACKME / ROOM WALKTHROUGH

# Lian\_Yu

## My first write-up

A record of my investigation, including the unsuccessful attempts and the clues that helped me move forward.

### 01 / Initial enumeration

I started by running an Nmap scan against the target IP address and saving the results to a file named Lian\_Yu. The scan showed four open ports: 21, 22, 80, and 111.

```
nmap -sS -A -vv -oN Lian_Yu 10.130.173.121
```

Command recorded in the scan output.

| PORT    | SERVICE |
|---------|---------|
| 21/tcp  | FTP     |
| 22/tcp  | SSH     |
| 80/tcp  | HTTP    |
| 111/tcp | rpcbind |

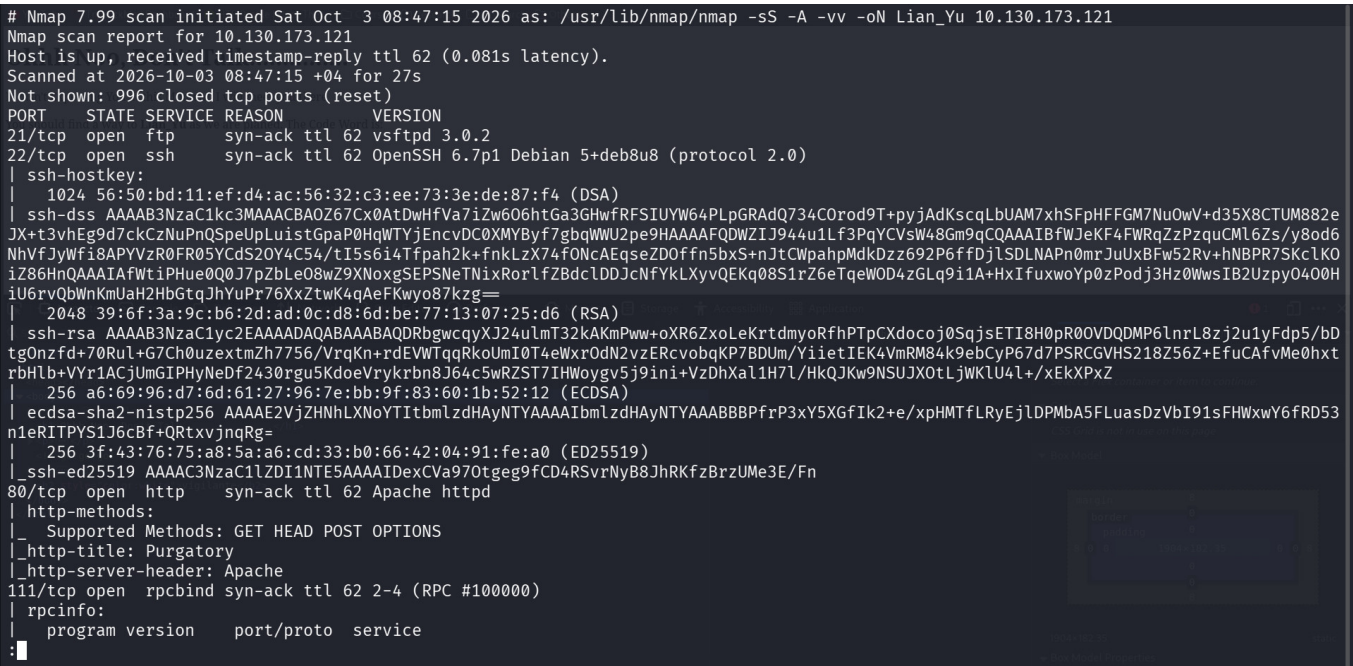


Figure 1. Nmap output showing four open TCP ports.

Room: <https://tryhackme.com/room/lianyu>

Public version: passwords and flags redacted.

## 02 / Exploring the web server

I investigated the web server first. The word "arrow," displayed in bold, caught my attention.

The room's second question suggested that I needed to find a directory with a numeric name. I ran Gobuster with a medium-sized wordlist and discovered /island. Inspecting the page's HTML source revealed a code: vigilante.

```
(senan@kali) - [~/Downloads]
$ gobuster dir -u http://10.130.173.121/ -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt

Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://10.130.173.121/
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8.2
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

Progress: 11895 / 220559 (5.39%)
Progress: 14217 / 220559 (6.45%)
island (Status: 301) [Size: 237] [→ http://10.130.173.121/island/]
server-status (Status: 403) [Size: 199]
Progress: 220558 / 220558 (100.00%)

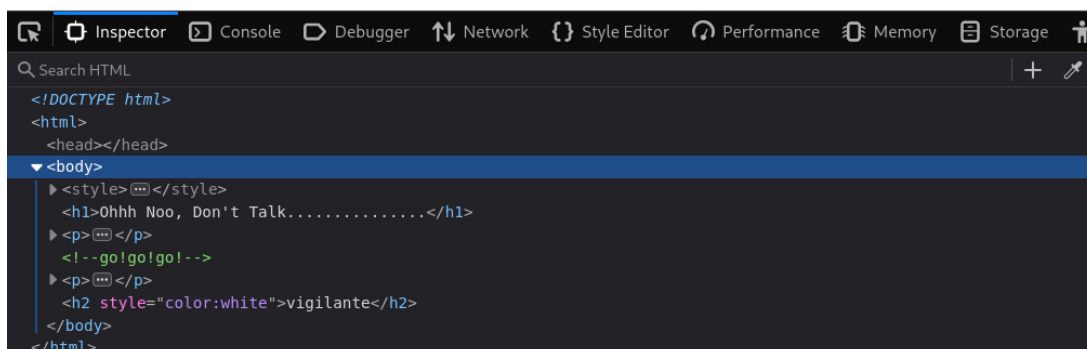
Finished
```

Figure 2. Gobuster discovers /island using directory-list-2.3-medium.txt.

### Ohhh Noo, Don't Talk.....

I wasn't Expecting You at this Moment. I will meet you there

You should find a way to **Lian\_Yu** as we are planed. The Code Word is:



```
<!DOCTYPE html>
<html>
  <head></head>
  <body>
    <style></style>
    <h1>Ohhh Noo, Don't Talk.....</h1>
    <p></p>
    <!--go!go!go!-->
    <p></p>
    <h2 style="color:white">vigilante</h2>
  </body>
</html>
```

Figure 3. The page inspector reveals the code word vigilante.

I initially tried vigilante as the FTP password for the usernames arrow and Lian\_Yu, but neither attempt succeeded.

## 03 / Finding the hidden paths

To search for the numeric directory, I created a wordlist containing the numbers 1 through 9999:

```
seq 1 9999 > numbers.txt
```

I used this wordlist with Gobuster against the website's root path, but the scan returned no matches. I suspected that my earlier scan had not searched inside /island, so I ran another scan against that path using the same wordlist. This revealed /island/2100.

```
(senan@kali)-[~/Downloads]
$ gobuster dir -u http://10.130.173.121/island/ -w numbers.txt

Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url:                http://10.130.173.121/island/
[+] Method:             GET
[+] Threads:            10
[+] Wordlist:            numbers.txt
[+] Negative Status codes: 404
[+] User Agent:          gobuster/3.8.2
[+] Timeout:            10s

Starting gobuster in directory enumeration mode

2100 (Status: 301) [Size: 242] [→ http://10.130.173.121/island/2100/]
Progress: 9999 / 9999 (100.00%)

Finished
```

Figure 4. A numeric wordlist reveals /island/2100.

I tried opening the YouTube link on that page, but I could not access the video. I then inspected the HTML source and found another clue: .ticket.

### Searching for the .ticket file

I interpreted .ticket as a hint about a file extension. Running Gobuster against /island/2100 without specifying the extension had not found the file. After adding the -x option to search for files with the ticket extension, I discovered green\_arrow.ticket.

```
(senan@kali)-[~]
$ gobuster dir -u http://10.130.173.121/island/2100/ -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt -x .ticket

Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url:                http://10.130.173.121/island/2100/
[+] Method:             GET
[+] Threads:            10
[+] Wordlist:            /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
[+] Negative Status codes: 404
[+] User Agent:          gobuster/3.8.2
[+] Extensions:         ticket
[+] Timeout:            10s

Starting gobuster in directory enumeration mode

green_arrow.ticket (Status: 200) [Size: 71]
Progress: 29234 / 441118 (6.63%)^C

(senan@kali)-[~]
```

Figure 5. Adding the extension finds green\_arrow.ticket.

## 04 / Decoding the token and accessing FTP

The file contained a token for accessing Queen's Gambit, described as a ship:

```
This is just a token to get into Queen's Gambit(Ship)
```

```
[ENCODED TOKEN REDACTED]
```

Figure 6. The token in green\_arrow.ticket references Queen's Gambit.

```
[ENCODED TOKEN REDACTED]
```

The hint for question 4 indicated that the token was encoded. I used CyberChef to decode it from Base58 and obtained:

```
[PASSWORD REDACTED]
```

At first, I did not know which username belonged with this password. I considered keywords I had encountered, including arrow, Lian\_Yu, Ship, Queen, and Gambit. I eventually realized that vigilante, the code from the /island page's source, was the username.

### Logging in as vigilante

I logged into FTP as vigilante and downloaded all three files to my desktop. I inspected them with the file command, which identified Leave\_me\_alone.png only as "data." This meant that the command had not recognized a more specific file type.

```
(senan@kali)-[~]  
$ ftp 10.130.173.121  
Connected to 10.130.173.121.  
220 (vsFTPd 3.0.2)  
Name (10.130.173.121:senan): vigilante  
331 Please specify the password.  
Password:  
230 Login successful.  
Remote system type is UNIX.  
Using binary mode to transfer files.  
ftp>
```

Figure 7. Successful FTP authentication as vigilante.

## 05 / Repairing the PNG and accessing SSH

I examined the beginning of the file with:

```
xxd -l 128 Leave_me_alone.png
```

```
(senan@kali)-[~]
$ xxd -l 128 Leave_me_alone.png
00000000: 5845 6fae 0a0d 1a0a 0000 000d 4948 4452 XEo... ..IHDR
00000010: 0000 034d 0000 01db 0806 0000 0017 a371 ..M.....q
00000020: 5b00 0020 0049 4441 5478 9cac bde9 7a24 [..IDATx...z$
00000030: 4b6e 2508 33f7 e092 6466 dea5 557b 6934 Kn%.3...df..U{i4
00000040: 6a69 54fd f573 cebc c03c 9c7e b4d4 a556 jiT..s...<~...V
00000050: 4955 75d7 5c98 5c22 c2dd 6c3e 00e7 c0e0 IUu.\.\."..l>...
00000060: 4e66 a94a 3d71 3f5e 32c9 085f cccd 60c0 Nf.J=q?^2...`..
00000070: c1c1 41f9 7ffe dfff bb2f eb22 fab5 aeab ..A...../.".....
```

Figure 8. The hex dump exposes the altered bytes at the start of the PNG.

The first four bytes did not match the expected PNG signature. I edited those bytes to restore the signature, which allowed me to open the image. At that point, I was not yet sure how to use its contents.

```
(senan@kali)-[~]
$ file Leave_me_alone.png
Leave_me_alone.png: data

(senan@kali)-[~]
$ hexeditor Leave_me_alone.png

(senan@kali)-[~]
$ file Leave_me_alone.png
Leave_me_alone.png: PNG image data, 845 x 475, 8-bit/color RGBA, non-interlaced
```

Figure 9. After the header repair, file recognizes the PNG image.

### Extracting hidden information

With some help, I learned that I could use steghide to extract hidden information from aa.jpg. Following the extraction process, I ended up with two files: passwd.txt and shado.

Running file shado did not identify it as a text file. However, reading it with cat revealed the password I later used for SSH.

### Accessing SSH and finding the user flag

I logged into SSH as slade and retrieved the user flag:

```
[FLAG REDACTED]
```

## 06 / Investigating privilege escalation

Next, I began looking for a way to gain root access. I read a hidden file named `.Important` in Slade's home directory. It directed me to look for `Secret_Mission`.

I considered using `find`, but tried `locate` first. It returned the following path:

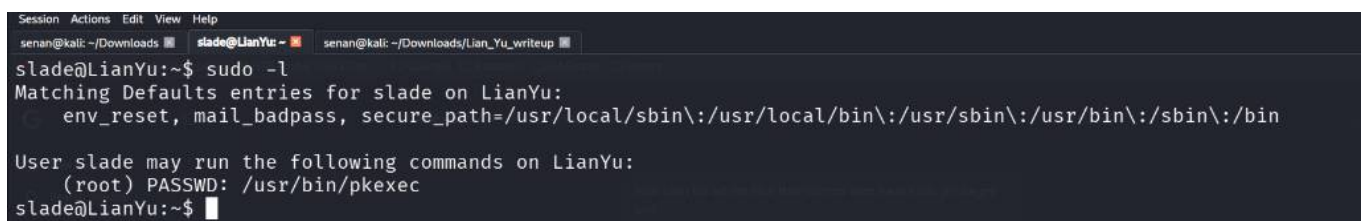
```
/usr/src/Secret_Mission
```

I also searched for other keywords from `.Important` using commands such as:

```
find / -iname "mikakuru"
find / -name "super power"
```

These searches did not return anything useful, so I moved on to checking Slade's sudo permissions:

```
sudo -l
```



```

Session Actions Edit View Help
senan@kali: ~/Downloads  slade@LianYu: ~  senan@kali: ~/Downloads/Lian_Yu_writeup
slade@LianYu:~$ sudo -l
Matching Defaults entries for slade on LianYu:
    env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

User slade may run the following commands on LianYu:
    (root) PASSWD: /usr/bin/pkexec
slade@LianYu:~$

```

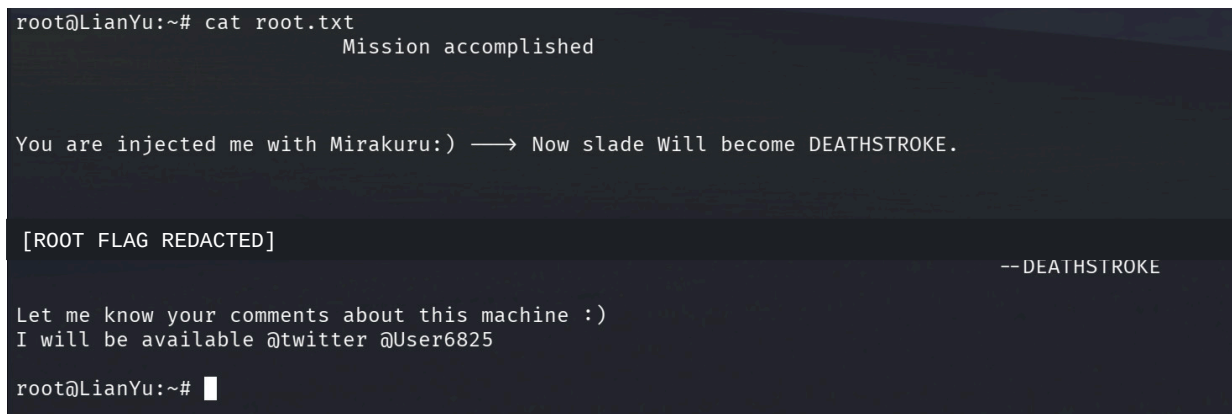
Figure 10. Slade is allowed to run `/usr/bin/pkexec` as root with authentication.

The output indicated that Slade could run `pkexec` as root after authenticating with the account's password.

I had recently learned about PwnKit (CVE-2021-4034), which was why `pkexec` was on my mind. After investigating further, I understood that the route I had found involved a sudo permission misconfiguration rather than exploiting PwnKit.

### Root access

Finally, I read `root.txt` from a root shell. The screenshot below records the successful outcome.



```

root@LianYu:~# cat root.txt
Mission accomplished

You are injected me with Mirakuru:) —> Now slade Will become DEATHSTROKE.

[ROOT FLAG REDACTED]
--DEATHSTROKE

Let me know your comments about this machine :)
I will be available @twitter @User6825
root@LianYu:~#

```

Figure 11. The root shell and the contents of `root.txt`.

The command used to open the root shell was not recorded in the written notes.

### Closing note

This was my first TryHackMe write-up. I wrote the initial notes while working through the room, so I have kept the unsuccessful attempts and the reasoning that helped me move forward. Thanks for reading!